UNIT 5 · TOPIC 5.1

Application Code Vulnerabilities

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A web application builds its database queries by directly concatenating user-supplied search terms without any validation. Which attack does this coding practice most directly enable?

- ○ A. SQL injection
- ○ B. Cross-site request forgery (CSRF)
- ○ C. Distributed denial-of-service (DDoS)
- ○ D. ARP spoofing

2. When evaluating the risk of an application vulnerability, "likelihood" refers to which of the following?

- ○ A. The probability that an attacker will discover and exploit the vulnerability
- ○ B. The severity of data loss if the vulnerability is successfully exploited
- ○ C. The number of user records stored in the affected database
- ○ D. The time required to develop and deploy a patch

3. A web application displays detailed database error messages to users whenever a query fails. Which risk does this behavior most directly create?

- ○ A. It increases the application's availability by surfacing server-side diagnostics.
- ○ B. It provides attackers with schema details and query structure useful for crafting injection attacks.
- ○ C. It reduces the need for user authentication.
- ○ D. It automatically encrypts sensitive data sent to the browser.

4. A healthcare portal stores patient records in a backend database and builds SQL queries by concatenating unvalidated user search terms. Which statement best explains why this represents a high-impact risk?

- ○ A. An attacker could craft input to extract, modify, or delete protected health records, threatening confidentiality, integrity, and potentially availability.
- ○ B. Unvalidated SQL queries consume excessive server resources, degrading performance for all users.
- ○ C. Unvalidated input increases database storage size, creating an availability risk.
- ○ D. The absence of input validation prevents the application from generating audit logs.

5. An analyst rates a path traversal vulnerability as high likelihood because the application is publicly accessible and the vulnerability class appears in the OWASP Top 10. Which factor most directly justifies this likelihood rating?

- ○ A. The number of files stored in the application's upload directory
- ○ B. The sensitivity classification of data that could be accessed if exploited
- ○ C. The broad internet exposure of the application combined with documented, widely available exploitation techniques for this vulnerability class
- ○ D. The absence of multi-factor authentication on administrator accounts

6. A stored cross-site scripting (XSS) vulnerability allows an attacker to inject malicious scripts into a comment field. Other users who load the page containing that comment have the attacker's script execute in their browsers. How does this attack exploit the application vulnerability?

- ○ A. It overflows the web server's memory, causing the application to crash and become unavailable.
- ○ B. It intercepts encrypted network packets between users and the server to extract session tokens.
- ○ C. It escalates the attacker's privileges directly on the server by modifying configuration files.
- ○ D. It uses the application as a persistent delivery mechanism, injecting code that executes in victims' browsers whenever they view the compromised content.

7. An e-commerce platform uses a third-party deserialization library to process session tokens. A critical remote code execution (RCE) vulnerability in this library was publicly disclosed 48 hours ago (CVSSv3 score: 9.8). The platform's WAF blocks known exploit signatures, but the vulnerability is too new for comprehensive signature coverage. Evaluating both likelihood and impact, which risk classification is most defensible?

- ○ A. High likelihood, high impact, a critical CVSSv3 score combined with an active disclosure window and signature-incomplete WAF coverage makes exploitation both probable and potentially catastrophic.
- ○ B. Low likelihood, high impact, WAF mitigation reduces the attack surface sufficiently to lower likelihood despite the critical CVSSv3 score.
- ○ C. Low likelihood, low impact, RCE via a session library only affects session token processing, not user data or application logic.
- ○ D. High likelihood, low impact, WAF signature controls cap the maximum achievable damage even if an attacker bypasses initial detection.

8. A banking application accepts XML input from partner APIs without disabling external entity processing. An independent audit rates this XXE vulnerability as medium likelihood but critical impact, internal network topology could be exposed. A development lead argues the risk should be downgraded because "no partner has reported exploiting it." Which counterargument most accurately challenges this reasoning?

- ○ A. Absence of reported exploitation does not imply absence of exploitation; advanced persistent threat actors rarely announce intrusions, and likelihood must be assessed against attacker capability and motivation, not incident-reporting history alone.
- ○ B. Partners are contractually obligated to report security incidents, so the absence of reports confirms the vulnerability has not been exploited.
- ○ C. XXE attacks only expose file contents, not credentials, so impact should be reclassified as low regardless of what network information is accessible.
- ○ D. WAF rules can reliably detect and block all XXE payload variants, so the risk is acceptable without remediation.

9. A penetration test of a SaaS platform reveals two vulnerabilities: (1) an unauthenticated reflected XSS in a rarely visited admin diagnostics page, and (2) an insecure direct object reference (IDOR) in the user profile API that allows any authenticated user to read any other user's billing records. Resources allow patching only one before the next release. Which risk evaluation most defensibly supports prioritizing the IDOR?

- ○ A. XSS is listed before IDOR in the OWASP Top 10, making XSS inherently higher priority regardless of context.
- ○ B. The reflected XSS should be prioritized because unauthenticated attack surfaces always present greater inherent risk than authenticated ones.
- ○ C. IDOR should always be prioritized over XSS because API vulnerabilities are categorically more severe than UI vulnerabilities.
- ○ D. The IDOR presents direct, immediately exploitable data exposure at scale for all authenticated users, whereas the reflected XSS requires attacker-controlled social engineering to reach a low-traffic page, significantly limiting its realistic likelihood.

10. A risk register is a structured document used to record cybersecurity risks. Which pair of elements is most essential to include for each entry?

- ○ A. Employee usernames and their corresponding salary data
- ○ B. Likelihood of occurrence and potential impact
- ○ C. Application source code version numbers and deployment timestamps
- ○ D. Network topology diagrams and server hardware specifications

11. Which of the following best describes the purpose of documenting application vulnerabilities in a structured format?

- ○ A. To replace the need for endpoint antivirus software
- ○ B. To maintain a record of known weaknesses so they can be prioritized, tracked, and remediated
- ○ C. To satisfy government export control compliance requirements
- ○ D. To establish legal accountability when a security incident occurs

12. An AI-assisted scanning tool identifies a path traversal vulnerability in a company's web application. What is the analyst's most appropriate next step?

- ○ A. Immediately take the web application offline and delete its files from the server
- ○ B. Notify all users that their data has been breached
- ○ C. Document the vulnerability's location, severity, and potential impact in the organization's risk register and assign it to the remediation queue
- ○ D. Rewrite the entire application from scratch using a different framework

13. An AI-powered DAST tool produces the following finding: "Command injection vulnerability in /api/ping; CVSSv3 8.6; exploitable remotely without authentication." Which additional information must the analyst add to make this a complete, actionable risk documentation entry?

- ○ A. The name and version of the AI vendor that produced the scan
- ○ B. The affected component, attack vector, CVSSv3 score, recommended mitigation, and an assigned risk owner
- ○ C. A full inventory of every HTTP endpoint in the application, including those not flagged by the scan
- ○ D. The organization's complete network diagram and physical asset list

14. During a code review, a developer identifies an insecure deserialization flaw in a Python application that processes untrusted user uploads and logs it as "medium severity, deserialization bug in upload handler." Why is this documentation insufficient for risk management purposes?

- ○ A. The entry omits likelihood of exploitation, potential impact on systems and data, affected assets, and recommended remediation, information necessary for the organization to prioritize and act on the risk.
- ○ B. Medium severity is always an inappropriate rating for deserialization flaws, which must be rated critical.
- ○ C. Developers are not authorized to document security risks; documentation authority belongs exclusively to security analysts.
- ○ D. Vulnerabilities should only be formally documented after exploitation is confirmed, to ensure accuracy of impact data.

15. An AI scanner flags 47 issues in a newly deployed e-commerce application, ranging from missing security headers to a critical SQL injection flaw. A project manager instructs the security team to document only the issues scheduled for the current sprint. Why does this approach undermine risk management?

- ○ A. Undocumented risks remain invisible to all stakeholders, they cannot be formally accepted, transferred, or tracked, and may be exploited before they are ever acknowledged.

○ B. Documenting fewer issues conserves storage resources, which outweighs any security concern in a sprint-based context.

○ C. Project managers require prior security team approval before any vulnerability documentation decisions can be made.

○ D. AI-generated findings are too unreliable to document without manual confirmation of every individual issue first.

16. A fintech startup uses an AI-powered DAST tool producing weekly reports exported as PDFs to a shared folder. Six months later, a regulator requests evidence that a critical IDOR vulnerability found in month 2 was properly remediated. The security team cannot reconstruct a remediation timeline. Which documentation practice would have most directly prevented this governance gap?

○ A. Maintaining a living risk register linking each vulnerability to its discovery date, assigned owner, remediation actions, verification evidence, and formal closure date, updated continuously as findings progress through the remediation lifecycle

○ B. Running DAST scans daily instead of weekly to generate a denser audit trail

○ C. Storing PDF reports in a version-controlled repository to preserve scan history

○ D. Restricting formal documentation to findings with CVSSv3 scores above 7.0 to reduce administrative overhead

17. A security team documents an XML injection vulnerability in a legacy internal application as "Low priority, internal only, limited user base." Three months later, the application is integrated into a customer-facing portal without a new security assessment. Which deficiency in the original risk documentation most directly contributed to this governance failure?

○ A. The documentation lacked a scope and context statement specifying the conditions under which the rating was valid, it assumed a static deployment context, making the rating obsolete once the application's exposure changed.

○ B. The team used qualitative risk ratings rather than quantitative CVSSv3 scores.

○ C. All vulnerabilities in legacy applications should be classified critical as a blanket precaution against future integration scenarios.

○ D. Risk documentation for internal applications should be classified confidential and withheld from integration teams to prevent security theater.

18. A security engineer must document a server-side template injection (SSTI) vulnerability in a customer-facing reporting tool and present the risk to non-technical executives to secure remediation budget. Which documentation approach best serves this audience while maintaining technical accuracy?

○ A. Present the raw CVSSv3 vector string and score without further translation, as executives should rely on standardized industry metrics for decision-making.

○ B. Describe the vulnerability using full OWASP nomenclature and exploitation technique details so executives can appreciate the precise technical severity.

○ C. Translate technical findings into business impact language, estimating potential data exposure scope, regulatory penalty exposure, and reputational consequences, while linking to full technical documentation for security staff, and including a cost comparison between remediation effort and estimated breach costs.

○ D. Characterize the finding as "a minor software bug" pending patch availability to avoid alarming executives before a fix is ready.